

01

КРИТИЧЕСКИЙ

Отключён модуль безопасности или WAF

- Включить Проактивный фильтр и модуль security
- Удалить широкие исключения WAF; ограничить точным путём
- Включить логирование событий; передавать в syslog / SIEM
- Проверять настройки после каждого обновления и миграции

02

ВЫСОКИЙ

WAF не заменяет безопасный код

- WAF — эшелонированная защита, не финальное исправление
- Исправлять в коде: валидацию, авторизацию, параметризацию
- Проверять обходы: кодировки, API, HTTP-методы, типы содержимого
- Виртуальный патч ставить с датой окончания и задачей на исправление

03

КРИТИЧЕСКИЙ

Уязвимый код, модули, зависимости

- Обновлять ядро, модули, PHP, ОС и JS-зависимости регулярно
- Вести реестр компонентов / SBOM с владельцем и сроком поддержки
- SAST и SCA для пользовательского PHP, JS, Composer, npm
- Удалять неиспользуемые модули полностью, не только скрывать

04

КРИТИЧЕСКИЙ

Доработки блокируют обновление CMS

- Не изменять файлы ядра Bitrix напрямую
- Хранить кастомный код в поддерживаемых /local/ директориях
- Тестировать обновление в staging перед применением в prod
- Документировать кастомизации, владельцев и порядок отката

05

КРИТИЧЕСКИЙ

Публичные скрипты установки и обслуживания

- Удалять bitrixsetup.php, restore.php сразу после использования
- Служебные скрипты хранить вне webroot; переносить на время окна
- Рекурсивно искать суффиксы .bak .old .save .zip
- Добавить внешние проверки известных путей установщиков в CI/CD

06

КРИТИЧЕСКИЙ

Чувствительные файлы и каталоги в webroot

- Дампы, резервные копии, .git — переместить вне webroot
- Запретить на сервере: .env *.sql *.log .git *.tar.gz
- Отключить листинг каталогов и MIME-sniffing
- Проверять снаружи: .git/HEAD .env phpinfo.php dbconn.php

07

ВЫСОКИЙ

Режим отладки и небезопасные логи в production

- debug=false, display_errors=0ff, Xdebug отключён
- Маскировать секреты, cookie, токены и ПДн в логах
- Хранить логи вне webroot: /var/log/bitrix/
- Ротация, квоты, доступ только сервисному аккаунту

08

КРИТИЧЕСКИЙ

Слабая аутентификация и управление привилегиями

- MFA обязателен для всех привилегированных аккаунтов
- Ограничить доступ к admin через VPN или сетевые ACL
- Индивидуальные аккаунты; принцип минимума привилегий
- Логировать входы, смены прав, сброс паролей, отключение MFA

09

КРИТИЧЕСКИЙ

Небезопасная конфигурация сервера / PHP / TLS

- HTTPS + современный TLS + HSTS на всех поддоменах
- Запретить выполнение PHP в /upload, /cache, /tmp
- PHP: скрыть версию, disable_functions, отдельные права процессов
- Валидировать загрузки: расширение, MIME, сигнатура, размер

10

ВЫСОКИЙ

Нет AV/EDR и централизованных логов

- Развернуть независимый AV/EDR на хосте (не только Bitrix WAF)
- Контроль целостности для файлов ядра, конфигов, cron-задач и SSH-ключей
- Передавать события в SIEM — не хранить только локально
- Проверять восстановление резервных копий регулярно